# ISO 27001:2022 Security Controls Assessment

**Northstar Technologies | Simulated internal assessment | 20 October 2026**

Portfolio training exercise. All company details, system outputs, evidence, findings and staff roles in this package are fictional. This is not an ISO certification audit, attestation, or evidence of work for a real employer.

## Executive summary

Eight selected Annex A controls were evaluated against a defined fictional company scope. Four controls met the limited sample criteria; four showed documented gaps. These statuses reflect only the mock tests and cannot establish overall ISO 27001 compliance.

## Scope and assumptions

In-scope: 75 workforce identities, 75 managed Windows laptops, Microsoft 365 collaboration, Microsoft Defender endpoint tooling, a centralized SIEM, documented policies and selected operational records. Out of scope: suppliers, physical sites, software development lifecycle, formal ISMS requirements, and any broader certification readiness.

## Assessment method

For each control: identify expected company policy, request sample evidence, test samples against that policy, record a concise finding, assign a qualitative risk rating and remediation owner. A pass is a sampled test result, not a blanket declaration of compliance.

## Control results

| Control | Observed fictional result | Outcome |
|---|---|---|
| A.5.15 | Approved access policy; sampled approvals on file | Pass |
| A.5.18 | Quarterly access review overdue | Gap |
| A.6.3 | 45 of 75 staff completed required training | Gap |
| A.8.1 | 72 of 75 endpoints meet configuration baseline | Gap |
| A.8.7 | EDR installed and healthy on 75 endpoints | Pass |
| A.8.8 | Three critical vulnerabilities beyond 14-day target | Gap |
| A.8.15 | Required authentication/endpoint logs found | Pass |
| A.8.16 | Five sampled alerts show triage and escalation | Pass |

## Key findings and corrective actions

## F-001 | A.5.18 | High

Review user access immediately; document owner approval and evidence. Formalize quarterly access reviews with reminders and escalation for missed cycles.

## F-002 | A.6.3 | Medium

Follow up with the 30 staff members without completed training. Track participation against the company-defined 90% objective and report residual exceptions.

## F-003 | A.8.1 | Medium

Investigate three noncompliant Windows devices; repair configuration drift or document exception and compensating controls; verify via new device compliance export.

## F-004 | A.8.8 | High

Triage three overdue critical findings by exposure and exploitability, assign owners, apply fixes or an approved exception, and rescan to verify closure.

## Limitations

Evidence is fabricated for learning. A full ISO 27001 audit would require broader ISMS clause coverage, justified Annex A applicability, test population definitions, actual supporting evidence and an appropriate audit methodology.

## Portfolio interpretation

This sample demonstrates assessment design, evidence tracking, risk-based recommendations and reporting. It should always be labeled an independent simulated project on a resume.

## References

ISO/IEC 27001:2022 Annex A (official standard governs authoritative control wording). Background: https://www.iso.org/standard/27001 ; control overview: https://www.isms.online/iso-27001/annex-a-2022/5-15-access-control-2022/